

SOLUTION BRIEF · VULNERABILITY MITIGATION

Verified mitigation for the post-Mythos zero-day clock.

Tracecat agents prove which scanner findings are really exploitable at your ingress, propose a narrow compensating control, and let one analyst approve, apply, and retest it in minutes — on your infrastructure, with your models.

- Open source, AGPL v3.0
- Self-hosted & air-gapped
- Bring your own LLM
- 500+ integrations

At a glance

THREAT

Unauthenticated RCE or auth bypass on internet-facing services: Grafana admin, Kubernetes dashboards, workflow and web apps

TRIGGER

Scanner finding (Nuclei or your vulnerability scanner) with a version match but no proof of impact

OUTCOME

Route-scoped WAF control. Attack denied, required traffic preserved, evidence on the case

DEPLOY

Self-hosted, air-gapped capable. vLLM, Ollama, LiteLLM, or hosted models

Default Workspace

Workspace

Chat

Beta

Workflows

Cases

Agents

Tables

Variables

Credentials

Integrations

MCP servers

Skills

Actions

Monitor

Runs

Inbox

Inbox

Search sessions...

Filter 1

Filtered by case 80d99999

Title

Source

Updated

Completed 1

Analyst

Case

Sep 7, 10:31

Analyst

Completed

Conclusion: Fresh bounded verification returned confirmed_rce for CVE-2026-21858 at the exposed supplier-intake ingress.

Status

Confirmed RCE

Malice

Pre-auth exploitation confirmed

Action

BLOCK proposal persisted; awaiting approval

Context

Tested ingress only; benign traffic passed

What I found: Unauthenticated command execution through the intake route. Cleanup completed and verification-created state removed.

What this means: Exposure is real, not a version match. Required traffic (upload, webhook, login, health) still passes.

What I need from you: Approve Create BLOCK rule, or rehearse with Create LOG-only rule first.

Type to ask follow-up questions...

gpt-5.6-terra

openai

The Analyst session in the Inbox: fixed-target verification confirmed exploitability, wrote sanitised evidence and a route-scoped BLOCK proposal to the case, and asked one human for one decision.

- WORKS WITH
- ProjectDiscovery Nuclei

Cloudflare

BunkerWeb / ModSecurity

aws AWS

Kubernetes

CISA KEV

FIRST EPSS

Shodan

CrowdStrike Falcon

Slack

Jira

PagerDuty

Key highlights

<2 min

Scanner signal to a verified, retested control; full loop measured at 78–102 s, 15 of 15 acceptance gates.

0

Firewall credentials or free-form rule syntax exposed to the agent, which can propose but never apply.

100%

Required traffic preserved: upload, webhook, login, and health are retested on every apply.

1 click

Human approval applies the exact reviewed rule, verifies activation, and rolls back on failure.

Same day

Exposure window per finding, versus a 55–61 day industry patch MTTR (Edgescan; modeled).

The problem

Discovery has gone machine-scale. Anthropic's Project Glasswing (Claude Mythos, Apr–May 2026) reported 23,019 issues across 1,000+ open-source projects, 10,000+ of them high or critical, and more than 99% unpatched at disclosure. OpenAI's GPT-6 Astra (Sep 3, 2026) is the first model rated "Critical" for cyber under its Preparedness Framework, and found and exploited two zero-days unaided. Open-weight Z.ai GLM-5.3 claims 2,436 findings across 269 projects and 105 of 130 ExploitGym targets, and anyone, including attackers, can run it.

The zero-day clock is negative. Mandiant/GTIG time-to-exploit fell from 63 days (2018–19) to 5 days (2023), then to about –1 day (2024) and about –7 days (2025). VulnCheck's 1H-2026 data shows 23% of KEVs exploited on or before CVE publication. Defender patch MTTR is still 55–61 days, and about 60% of breaches involve a vulnerability with a patch already available.

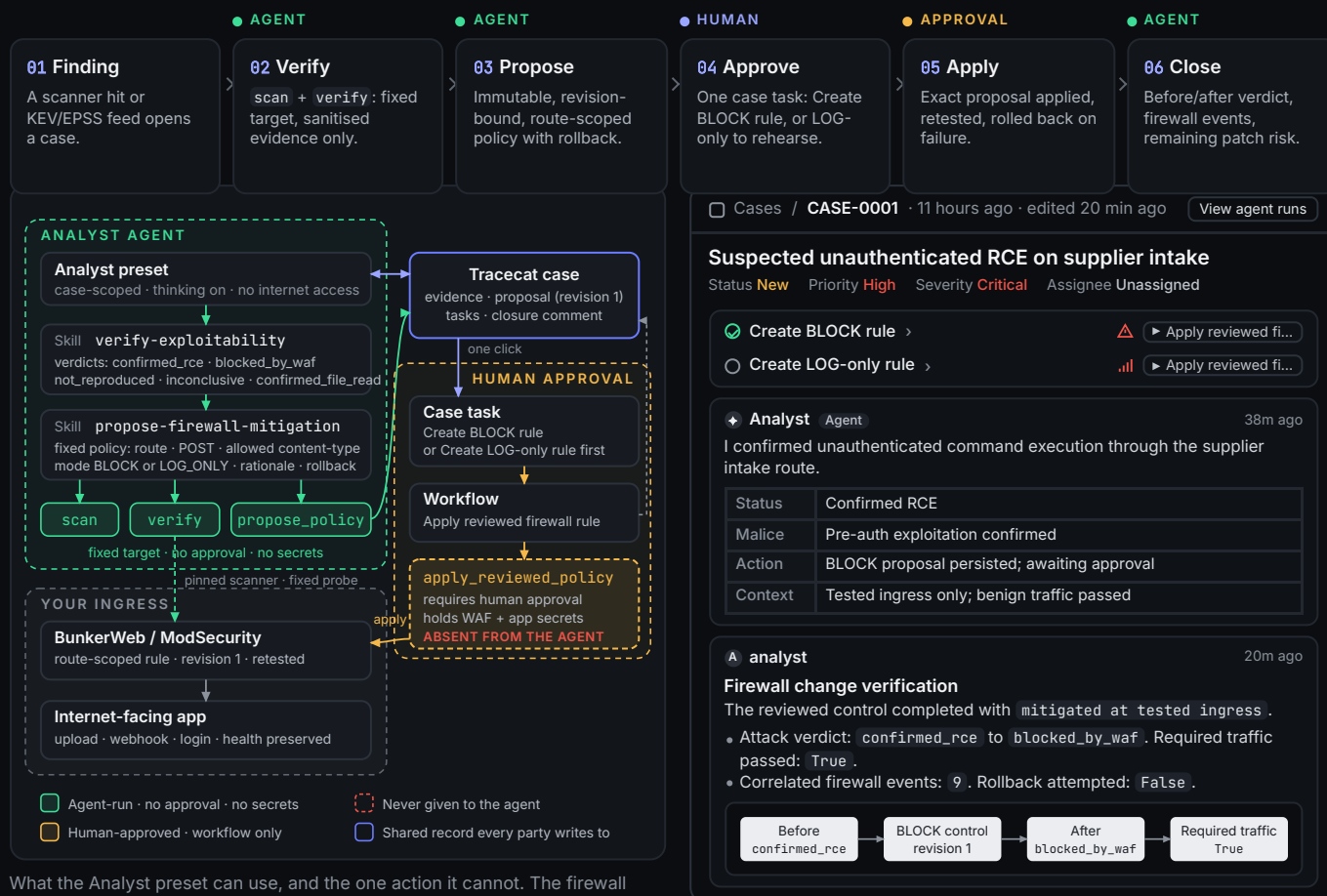
Where teams get stuck. Vulnerability management receives thousands of version-match findings and cannot tell exploitable from noise. Patching waits on owners and change windows. A hand-written WAF rule is risky (a global JSON or POST block breaks the business), so nobody writes one, and the finding sits open. Every hour is exposure.

SARONIC
“Tracecat is a cheat code for corporate security teams that want to build and own their own agentic future.”
Principal Threat Researcher, Saronic

neo
“A genuine thank you to the team. I built an end-to-end IoC enrichment pipeline with Claude and Tracecat MCP and created more value for our SOC in a day than I probably would have in weeks on my own. You're making my one-man SOC assignment possible.”
Senior Security Engineer, Neo Financial

Verify first. Contain narrowly. Keep the analyst in command.

How the Tracecat Analyst turns a scanner finding into a reviewed, retested ingress control.



What the Analyst preset can use, and the one action it cannot. The firewall credential exists only inside the human-launched workflow.

The case at the approval moment: the confirmed-RCE comment, two human-owned tasks bound to the apply workflow, and the closure verdict.

Return on investment

A modeled month for one team. Every input is an assumption; swap in your own volumes, hours, and rates. The control is mitigation at the tested ingress, not a patch.

ASSUMPTIONS · REPLACE WITH YOUR OWN

INPUTS

Internet-facing high/critical findings needing exploitability triage	30 / month
Manual path per finding validate 2h · author and test a compatible WAF rule 3h · retest and document 1h	≈ 6 h
Tracecat path per finding review evidence · approve · read the closure	≈ 0.5 h
Loaded analyst cost	\$125 / h

OUTPUTS

Analyst hours returned each month	165 h
Value of returned analyst time	≈ \$20.6k / month ≈ \$248k / year
Exposure window per finding	55–61 days → same shift finding
Acceptance checks on every apply	15 automated

Not counted: breach-cost avoidance (IBM Cost of a Data Breach 2025, global average \$4.44M per incident).

Why Tracecat

What makes this loop safe to run on the finding that matters.

Your network, your models.

Self-host in your VPC, on-prem, or fully air-gapped on Kubernetes with zero internet routes. Point agents at vLLM or Ollama, directly or via bundled LiteLLM. Evidence never leaves your boundary.

Bounded tools, not a shell.

Fixed-target Python actions with pinned dependencies. The agent gets scan, verify, propose; never the firewall credential or rule syntax. Default-deny tool policy, sandboxing, full audit log.

Integrations in an afternoon.

Any WAF, scanner, or ticketing system becomes an agent tool via a Python file or YAML template (500+ integrations, 50+ MCP servers). Tracecat MCP turns a Claude Code, Codex, or Cursor prompt into workflows, tasks, and skills.

Analysts stay in command.

Immutable, revision-bound proposals, one-click approval, automatic rollback, LOG-only rehearsal. Skills and memory are versioned and reviewed. Open source under AGPL v3.0, so the operating model is inspectable.

Talk to a Tracecat expert

Discuss your exposed services, scanner feeds, WAF estate, and approval requirements with the Tracecat team.

[Book a demo](#)

tracecat.com/contact →

tracecat.com docs.tracecat.com github.com/TracecatHQ/tracecat

Sources. Anthropic, Project Glasswing update (May 26, 2026) · OpenAI, GPT-6 Astra announcement (Sep 3, 2026) · Z.ai, GLM-5.3 release · Mandiant / Google Threat Intelligence Group, time-to-exploit analyses · VulnCheck, 1H-2026 exploitation report · Edgescan, vulnerability statistics (patch MTTR) · IBM, Cost of a Data Breach Report 2025. Loop timings and gate counts are from Tracecat's reference environment for this scenario. Every Tracecat feature works offline; see docs.tracecat.com/self-hosting/air-gapped.